

1 Objetivos

Esta fase do trabalho estende a anterior, possibilitando aos alunos experimentarem diversos mecanismos de segurança, tais como: autenticação, MACs, comunicação com um protocolo seguro (TLS – Transport Layer Security) e gestão básica de certificados.

A envolvente do trabalho continua a ser a mesma, ou seja, a concretização de um sistema simplificado de armazenamento de ficheiros, designado por *mySaude*, onde os utilizadores usam um servidor central para armazenar ficheiros de utentes (resultados de exames, declarações, prescrições, etc).

2 Modelo de adversário

Iremos assumir no trabalho que existe um adversário que pretende comprometer o correto funcionamento do sistema. O adversário terá um conjunto de capacidades que poderão ser empregues na realização das suas ações maliciosas. Torna-se assim necessário dotar o sistema dos mecanismos de proteção que lhe possibilitem manter um funcionamento correto ainda que se encontre sob ataque.

Vamos assumir que o adversário tem as seguintes capacidades:

- Acesso à rede: tendo o adversário acesso à rede, poderá escutar os pacotes trocados entre o cliente e o servidor. Potencialmente, também poderá tentar corromper, alterar, introduzir, e reproduzir mensagens para enganar quer o cliente, quer o servidor.
- Controlar um ou mais utilizadores: o adversário controla uma (ou mais) conta(s) de utilizadores do sistema. Através desta(s) conta(s), ele poderia tentar aceder a ficheiros para os quais não tem permissões ou corromper ficheiros com informação de outros utilizadores.
- Acesso à máquina onde o servidor é executado, em modo de leitura: o adversário tem acesso em modo de leitura aos ficheiros armazenados no servidor. Com esse acesso, ele pode potencialmente observar informação que eventualmente seria confidencial.

Em seguida indicam-se e discutem-se as proteções que devem ser adicionadas ao sistema.

3 Alterações a adicionar ao sistema

Nesta fase, os alunos devem usar a mesma arquitetura da 1ª fase. Adicionalmente, o sistema deve ser estendido para poder ser usado por vários utilizadores autenticados.

De seguida são descritas as alterações a adicionar ao sistema.

A. Confidencialidade de *passwords*

O servidor mantém um ficheiro (designado por *users*) com os utilizadores do sistema e respetivas informações. Este ficheiro deve **ser um ficheiro de texto**. Cada linha tem um *username*, a função do utilizador e a respetiva password (com o **salt**), separador por “:”

```
silva:medico:w9CfDqX9Li5krpdJZgg/Qh:A46KPmM+bClnR5D8URnVAzG9heNbvXop5eQ1leAcuk=  
bob:utente:ut4Ic9BfJNfFL2fJ+4IXGQ==:yn9ZU+vkUK/mtt+vuRU7az3yb4vWEPmoyXXRaI8nxIc=  
alice:medico:dbqPTW49yNLmOJK4RC:MAOgRGmbTqpWnDI5yIjZJICRG7CvKlRNOozCKx0QsyY=
```

Com esta informação, o servidor passará a identificar e autenticar os utilizadores e irá distinguir quem pode fazer as operações disponíveis no sistema.

Os utilizadores podem ter uma das seguintes funções: *medico*, *utente*.

O servidor deve proteger a **confidencialidade das passwords**. Com este objetivo, as passwords devem ser armazenadas utilizando um algoritmo de síntese com *salts* (deve ser usada a classe *MessageDigest*). As sínteses e os salts estão armazenados de acordo com a codificação base64.

Apenas as opções do *mySaude* que contatam o servidor requerem autenticação.

Questão para responder no relatório do trabalho: como é que a confidencialidade das passwords pode ser assegurada de forma mais segura do que a pedida neste trabalho ?

B. Integridade do ficheiro das passwords

O servidor deve proteger a **integridade do ficheiro das passwords**. Para tal, o ficheiro deve ser protegido com um MAC. O cálculo deste MAC utiliza uma chave simétrica obtida a partir da **password de mac do servidor**. O MAC deve ser calculado usando a classe MAC (com a norma HMAC e uma função de síntese segura).

No início da sua execução, o servidor pede a password do servidor e deve usar o MAC para verificar a integridade do ficheiro das passwords.

Se o MAC estiver errado, o servidor deve imprimir um aviso e terminar imediatamente a sua execução.

O MAC deve **ser verificado em todos os restantes acessos ao ficheiro das passwords e atualizado caso o ficheiro seja alterado**.

O MAC será guardado num ficheiro utilizado apenas para este efeito designado por *mySaude.mac*. O MAC deve ser guardado de acordo com a codificação base64.

A chave para ser usada na geração do MAC deve ser obtida a partir da password do MAC do seguinte modo (neste exemplo a password do MAC é *maria12*):

```
byte [] pass = "maria12".getBytes();
```

```
SecretKey key = new SecretKeySpec(pass, "HmacSHA256");
```

O array de bytes deve ser convertido para string do seguinte modo:

```
String s = Base64.getEncoder().encodeToString(bytearray);
```

C. Criação de utilizadores

O programa `criarUser` permite criar utilizadores **no lado do servidor** e acede diretamente ao ficheiro das passwords:

```
criarUser <username> <funcao> <password> -f <ficheiro com o certificado do utilizador>
```

onde

`<username>`, `<funcao>`, `<password>` e `<ficheiro com o certificado do utilizador>` correspondem ao *username*, à função, à *password* e ao ficheiro com o certificado do novo utilizador.

Este programa deve ainda pedir a **password de mac do servidor** (ver como é assegurada a integridade do ficheiro das passwords em C).

Caso seja introduzido um *username* já existente, deve ser devolvida uma mensagem de erro e o programa deve terminar. Caso seja introduzida uma função não válida, deve ser devolvida uma mensagem de erro e o programa deve terminar.

Exemplo:

```
criarUser maria medico ut12?!WE -f maria.cert
```

Com a criação de um novo utilizador, será criada também uma diretoria para esse utilizador no servidor, onde deverão ser guardados os ficheiros do utilizador.

O servidor mantém uma keystore (designada por keystore.users) usada **apenas para guardar os certificados dos utilizadores**. O programa criarUser adiciona o certificado do utilizador a esta keystore.

Simplificação: o username e o alias do certificado devem coincidir.

Observação: O MAC deve ser verificado em todos os acessos ao ficheiro das passwords e atualizado caso o ficheiro seja alterado.

D. Canal seguro

Na comunicação entre o cliente e o servidor pretende-se garantir a **autenticidade do servidor** (um atacante não deve ser capaz de fingir ser o servidor e assim obter a password de um utilizador) e a **confidencialidade** da comunicação entre cliente e servidor (um atacante não deve ser capaz de escutar a comunicação). Para este efeito, devem ser usados **canais seguros** (protocolo TLS/SSL). Este protocolo permite verificar a identidade do servidor utilizando chaves assimétricas.

E. Gestão dos certificados

O servidor mantém os certificados dos utilizadores numa keystore do servidor designada por keystore.users – ver criação de utilizadores.

As opções do trabalho 1 devem ser estendidas do seguinte modo: caso seja necessário um certificado de um utilizador que não exista na keystore do utilizador que está a usar o cliente *mySaude*, o cliente *mySaude* deve pedir o certificado ao servidor e adicioná-lo à keystore do utilizador. Deste modo, não é necessário fazer os *imports* dos certificados previamente.

F. Autenticação e Controlo de acesso

As opções do trabalho 1 devem ser estendidas do seguinte modo: apenas os utilizadores com a função *medico* podem enviar ficheiros para o servidor. As outras opções podem ser utilizadas por todos os utilizadores. As opções que não contactam o servidor não precisam de autenticar o utilizador.

4 Avaliação

A avaliação dos projetos será feita segundo uma abordagem funcional, onde cada funcionalidade descrita no enunciado deve ser apresentada pelos alunos. Não serão consideradas funcionalidades incompletas ou valorizada qualquer implementação não funcional. **É obrigatório apresentarem os trabalhos em três máquinas distintas do laboratório (servidor e 2 clientes em máquinas separadas)**. De preferência, devem utilizar o sistema operativo Linux.

Considere, por exemplo, o seguinte cenário.



Cada uma das opções/funcionalidades apresentadas será valorizada de acordo com a seguinte tabela:

Funcionalidade	Valorização	Validação
Gestão utilizadores		
A. Confidencialidade de passwords • Formato: user:funcao:salt:síntese(salt password)	2	
B. Integridade do ficheiro das passwords • Calcula o MAC e valida-o corretamente • Calcula um novo MAC sempre que há alterações • Valida o MAC no início e em todos os acessos • Apresenta mensagens de erro (quando MAC não existe, MAC incorreto, ...) • Funciona qualquer que seja a dimensão do ficheiro das passwords • Guarda mac em codificação base64	4	
C. Criação de user • Adiciona user • Verifica se já existe + msg de erro • Ciclo termina quando encontra • Funciona com qualquer nº de users	3	
D. Canal seguro (TLS/SSL)	3	
E. Gestão dos certificados • O criarUser adiciona certificados à keystore.users • Quando necessário, o cliente recebe certificados do servidor e adiciona-os à keystore do utilizador	1+2	
F. Autenticação e Controlo de acesso • Autenticação – verifica password correta e dá msg de erro • Algoritmo termina quando encontra • Funciona para ficheiro com qualquer número de utilizadores • Controlo de acesso – verifica funcao do user e dá msg de erro	2+1	
Usam algoritmos não seguros	Penalização de 1 valor por cada caso	
Relatório (e entrega dentro do prazo)	1	
Preparação da apresentação para a avaliação e cumprimento do tempo	1	

5 Entrega

Código:

Dia **3 de Maio**, até às 23:55 horas. O código do trabalho deve ser entregue na página da disciplina. Os alunos deverão submeter o código do trabalho num ficheiro zip e um Readme (txt) sobre como executar o trabalho.

Relatório:

Dia **4 de Maio**, até às 23:55 horas, no moodle.

No relatório devem ser apresentados e discutidos os seguintes aspetos:

- Os objetivos concretizados com êxito
- Os problemas encontrados
- Tabela de auto avaliação preenchida
- Análise crítica à segurança da aplicação criada, identificando 3 possíveis **fraquezas e melhorias** a incluir em versões futuras. Na análise crítica não devem focar-se nas limitações da vossa implementação, caso não tenham cumprido todos os requisitos. Deve considerar a aplicação final de acordo com os requisitos do trabalho. Observação: ver questão do enunciado.

O relatório deve ter no máximo 3 páginas.

Não serão aceites trabalhos por email nem por qualquer outro meio não definido nesta secção. Se não se verificar algum destes requisitos o trabalho é considerado não entregue.

Não serão aceites melhorias ao trabalho 2 depois desta data. A avaliação a ser efetuada do trabalho 2 no final do semestre será da versão entregue em 3 de Maio.

6 Avaliação dos Trabalhos

A avaliação dos trabalhos e dos alunos será efetuada nas 2 últimas semanas de aulas – ver plano das aulas.